CRISC Exam - Domain 4: Technology & Security

Technology Risk Questions 66–105 with Explanations

Compiled from ISACA CRISC Review Manual 8th Edition

October 19, 2026

Outline

1. Emerging Technologies
2. Security Frameworks & Access Control

Q66: Shadow IT Risk

Question

Why is shadow IT a significant risk to an enterprise?

A. It reduces IT costs

B. It puts the organization in a vulnerable position where its true risk profile is unknown even to senior executives

C. It improves security controls

D. It eliminates the need for IT governance

Q66: Explanation

Correct Answer: B

If the IT department is unwilling to review and integrate new technologies, it is possible that the business will find ways to implement them regardless, putting the organization in a vulnerable position where its true risk profile is unknown even to senior executives. This practice, sometimes called shadow IT, is surprisingly common.

Option Analysis

- **A - Incorrect:** Shadow IT often increases costs
- **B - Correct:** True risk profile becomes unknown
- **C - Incorrect:** Shadow IT bypasses security controls
- **D - Incorrect:** It increases the need for governance

Q67: Risk Practitioner and Emerging Tech

Question

What is the BEST approach for a risk practitioner when new technologies emerge?

A. Adopt an obstructionist posture and reject all new technology

B. Lead the effort to demonstrate how new technologies can be safely incorporated into the enterprise

C. Ignore new technologies until they are mandated

D. Delegate all technology decisions to the IT department

Q67: Explanation

Correct Answer: B

The risk practitioner is considerably more likely to get the attention and support of senior management by leading the effort to demonstrate how new technologies can be safely incorporated into the enterprise than by adopting an obstructionist posture. The best chance of maintaining relevance is to proactively suggest how technology can be put to use safely rather than seeking to reject its adoption.

Option Analysis

- **A - Incorrect:** Obstructionist posture loses influence
- **B - Correct:** Lead safe incorporation efforts
- **C - Incorrect:** Ignoring technology increases shadow IT
- **D - Incorrect:** Risk management is an enterprise responsibility

Q68: Omnipresent Connectivity and Behavior

Question

How has omnipresent connectivity changed human behavior in ways that create risk?

- A People are less likely to share information
- B People are more likely to share updates about their actions, locations, and experiences on social media as they happen
- C People have stopped using mobile devices
- D People are more careful about information privacy

Q68: Explanation

Correct Answer: B

People are more likely to share updates about their actions, locations, and experiences on social media as they happen, including livestream video feeds that may be taken without notice to those around them. Many users of powerful mobile devices demonstrate minimal awareness of or even interest in basic concepts of cybersecurity and information privacy.

Option Analysis

- **A - Incorrect:** People are more likely to share
- **B - Correct:** Increased sharing creates risk
- **C - Incorrect:** Mobile device use has increased
- **D - Incorrect:** Many users show minimal privacy awareness

Q69: IoT Device Security Priority

Question

Why do IoT devices tend to have weaker security than traditional IT systems?

- A Security features make things more expensive and slow them down, and functional tasks are often seen as part of physical plant concerns
- B IoT devices are always more secure
- C IoT devices are managed by the security team from the start
- D IoT devices do not connect to networks

Q69: Explanation

Correct Answer: A

IoT devices tend to prioritize functionality over security. The basic tension between operating efficiency and security is hard to overcome; security features make things more expensive and slow them down. Functional tasks linked to IoT devices also tend to be seen as part of the physical plant or facilities area of concern, receiving relatively little scrutiny within system life cycles or enterprise architecture.

Option Analysis

- **A** - **Correct:** Cost and speed trade-offs, seen as facilities concern
- **B** - **Incorrect:** IoT devices often have weaker security
- **C** - **Incorrect:** IoT is often managed by facilities, not security
- **D** - **Incorrect:** IoT devices are network-connected

Q70: IoT Guardrails Approach

Question

What is a recommended guardrails approach for managing IoT risk?

A. Ban all IoT devices

B. Place IoT traffic on a separate network and treat that environment as hostile cyberterrain

C. Connect IoT devices directly to critical systems

D. Ignore IoT devices since they are low risk

Q70: Explanation

Correct Answer: B

Where practical, it may be beneficial to place IoT traffic on a separate network and treat that environment as hostile cyberterrain. This sort of guardrails approach can allow IT operations and security staff to advocate for the benefits of IoT while maintaining acceptable levels of risk, rather than creating conditions under which IoT capabilities might be brought into the enterprise as a form of shadow IT.

Option Analysis

- **A** - **Incorrect:** Banning all IoT is often impractical
- **B** - **Correct:** Separate network as hostile cyberterrain
- **C** - **Incorrect:** Direct connection increases risk
- **D** - **Incorrect:** Ignoring IoT increases risk

Q71: Decryption and Massive Computing Power

Question

How has cloud computing changed the risk associated with encryption?

- A Encryption is no longer needed
- B It is now feasible for individuals or groups with modest means to perform brute-force attacks using rapidly provisioned computing power
- C Encryption has become unbreakable
- D Cloud providers cannot decrypt any data

Q71: Explanation

Correct Answer: B

Until recently, it was infeasible that anyone outside a well-funded government agency would be able to assemble sufficient processing power to break encryption. The ability to rapidly provision computing power through cloud providers has eliminated this restriction, with pattern analysis and brute-force attacks now within the grasp of individuals or groups with modest means.

Option Analysis

- **A** - **Incorrect:** Encryption remains vital
- **B** - **Correct:** Cloud enables brute-force attacks
- **C** - **Incorrect:** No encryption is unbreakable forever
- **D** - **Incorrect:** Providers can access unencrypted data

Q72: Quantum Computing and Encryption

Question

What does the emergence of quantum computing mean for encrypted data?

- A All encrypted data is safe forever
- B It is difficult to predict how long an encrypted file might protect data if it were stolen
- C Encryption will never need to change
- D Quantum computing has no impact on cryptography

Q72: Explanation

Correct Answer: B

For the risk practitioner, this means that it is difficult to predict how long an encrypted file might protect data if it were stolen. Encryption remains a vital part of information security, but it cannot be taken for granted that data is safe simply because it is encrypted. Quantum-resistant algorithms have already begun appearing, and maintaining awareness of these offerings can help reduce the risk.

Option Analysis

- **A - Incorrect:** No encryption is safe forever
- **B - Correct:** Prediction of protection duration is difficult
- **C - Incorrect:** Encryption must evolve
- **D - Incorrect:** Quantum computing impacts cryptography significantly

Q73: Deepfake Countermeasures

Question

Which combination of controls can help guard against deepfakes misdirecting operations?

A. Ignoring all verbal approvals

B. Security awareness and administrative controls such as requiring written approval or using a dedicated callback number

C. Relying solely on video identification

D. Eliminating all financial transfers

Q73: Explanation

Correct Answer: B

Risk practitioners can guard against deepfakes misdirecting operations through a combination of security awareness and administrative controls. For instance, requiring that a transaction not only have the verbal approval of the CEO but also written approval from another executive, or using a dedicated callback number to obtain confirmation after receiving initial outreach, can help inoculate an organization against this kind of technical deception.

Option Analysis

- **A - Incorrect:** Verbal approvals are still needed for operations
- **B - Correct:** Awareness plus administrative controls
- **C - Incorrect:** Video can be deepfaked
- **D - Incorrect:** Eliminating transfers is impractical

Q74: Deepfake Reputational Risk

Question

Why is deepfake technology a significant concern for reputational risk?

- A It only affects internal communications
- B It can create falsified video or audio recordings that impact public opinion, particularly for enterprises subject to public tensions
- C It is easy to detect by the average person
- D It cannot be used for political or commercial gain

Q74: Explanation

Correct Answer: B

No protective measures are sufficient to guard against impacts to public opinion that may arise from falsified video or audio recordings, particularly when dealing with enterprises or issues subject to substantial public tensions. Many people for whom it is easiest to gather the data points needed to produce deepfakes are in positions where reputational risk is significant. Until there is an easy way to identify deepfakes, deception for political or commercial gain will remain an emerging trend requiring a robust risk response.

Option Analysis

- **A** - **Incorrect:** Deepfakes affect public perception externally
- **B** - **Correct:** Public opinion impacts are significant
- **C** - **Incorrect:** Detection requires considerable expertise
- **D** - **Incorrect:** Deepfakes can be used for gain

Q75: Big Data Privacy - Reidentification

Question

What privacy risk occurs when data is aggregated and semianonymous information becomes identifiable?

- A Data minimization
- B Reidentification
- C Encryption
- D Hashing

Q75: Explanation

Correct Answer: B

When data is aggregated, semianonymous information or information that is not individually identifiable might become nonanonymous or identifiable in the process. This is reidentification. Privacy (reidentification) is a risk associated with big data analytics.

Option Analysis

- **A - Incorrect:** Data minimization reduces privacy risk
- **B - Correct:** Reidentification occurs through aggregation
- **C - Incorrect:** Encryption protects confidentiality
- **D - Incorrect:** Hashing protects integrity

Q76: Big Data - Data Deluge

Question

What challenge does "data deluge" present for big data initiatives?

A. It improves data quality

B. It can result in quality problems, and effective decisions cannot be made based on poor quality data

C. It reduces the need for governance

D. It eliminates the need for skilled staff

Q76: Explanation

Correct Answer: B

Data deluge can result in quality problems. Big data is of no value if it cannot be harnessed for better business decision making. Effective decisions cannot be made based on poor quality data. In addition, more complex and unstructured data is being introduced, which can strain data governance efforts.

Option Analysis

- **A - Incorrect:** Data deluge often degrades quality
- **B - Correct:** Quality problems impede decision-making
- **C - Incorrect:** It increases governance needs
- **D - Incorrect:** It increases the need for skilled staff

Q77: Blockchain Transparency

Question

What blockchain characteristic facilitates extraordinary transparency in transaction logging?

A. Centralized processing
B. The absence of centralization
C. Symmetric encryption only
D. Manual verification

Q77: Explanation

Correct Answer: B

The absence of centralization facilitates extraordinary transparency in transaction logging that is inherent to the blockchain structure. The chain structure makes it very difficult to falsify a blockchain entry because each entry contains both its own digital hash and the hash of the block before it.

Option Analysis

- **A - Incorrect:** Blockchain is decentralized
- **B - Correct:** Absence of centralization provides transparency
- **C - Incorrect:** Uses cryptographic hashing, not just symmetric
- **D - Incorrect:** Verification is automated through consensus

Q78: Blockchain Potential Beyond Cryptocurrency

Question

Which of the following is a potential application of blockchain technology beyond cryptocurrency?

A. Entertainment only
B. Healthcare, property titles, and voting
C. Only financial trading
D. No other applications exist

Q78: Explanation

Correct Answer: B

Blockchain has been touted as a way to revolutionize banking, healthcare, property titles, and even voting. Some of the promises made may prove to be baseless hype. However, risk practitioners in industries affected by blockchain should take care to remain apprised of what developments are underway.

Option Analysis

- **A - Incorrect:** Blockchain has many applications beyond entertainment
- **B - Correct:** Healthcare, property titles, voting
- **C - Incorrect:** Blockchain has applications beyond finance
- **D - Incorrect:** Many applications exist

Q79: AI Machine Learning Oversight

Question

Why is oversight especially important for machine learning (ML) systems?

A. ML systems never change their behavior

B. ML algorithms refine themselves over time based on results, and bad habits may be difficult to break

C. ML systems are always perfectly accurate

D. ML systems do not require human intervention

Q79: Explanation

Correct Answer: B

Oversight of AI is especially important in cases involving ML, algorithms designed to refine themselves over time based on results. Where "improvement" is poorly or incorrectly defined, iteration aimed at refining outcomes may result in lasting deviation from goals. Heuristic systems used in intrusion detection are one area of concern—an errant determination that malicious traffic is normal could result in willful blindness to an intrusion.

Option Analysis

- **A - Incorrect:** ML systems change their behavior
- **B - Correct:** Self-refining algorithms may deviate from goals
- **C - Incorrect:** ML systems can be inaccurate
- **D - Incorrect:** Human oversight is essential

Q80: AI and Sensitive Data

Question

What privacy and intellectual property risk may be overlooked when using AI?

- A AI never uses data for training
- B The use of sensitive and personally identifiable information (PII) to train AI models
- C AI only uses public data
- D AI eliminates all privacy concerns

Q80: Explanation

Correct Answer: B

The use of sensitive and personally identifiable information (PII) to train AI models presents privacy and intellectual property risk that may be overlooked using standard risk identification and assessment processes. The risk practitioner should ensure that privacy impact assessments (PIAs) and fundamental rights impact assessments (FRIAs) are part of the AI risk assessment process.

Option Analysis

- **A - Incorrect:** AI requires large amounts of training data
- **B - Correct:** PII in training data creates risk
- **C - Incorrect:** AI can use proprietary data
- **D - Incorrect:** AI can increase privacy concerns

Q81: CIA Triad Trade-offs

Question

Why is it impossible to simultaneously maximize all three principles of the CIA triad?

- A They are unrelated
- B Typically there are trade-offs between the three principles, making it impossible to increase one without decreasing another or substantially increasing cost
- C They are always perfectly aligned
- D Only one principle matters

Q81: Explanation

Correct Answer: B

There are typically trade-offs between the three principles in any system, making it impossible to simultaneously increase one of them without either decreasing at least one of the others or substantially increasing cost. For instance, increasing confidentiality typically increases processing time, which reduces availability.

Option Analysis

- **A - Incorrect:** They are closely related
- **B - Correct:** Trade-offs are inherent in the CIA triad
- **C - Incorrect:** They often conflict
- **D - Incorrect:** All three principles matter

Q82: Confidentiality - Need to Know

Question

What principle ensures that individuals are given access only to information they need to perform their job functions?

A. Least privilege
B. Need to know
C. Availability
D. Nonrepudiation

Q82: Explanation

Correct Answer: B

The need-to-know principle ensures that individuals are given access only to information that they need to perform their job functions. For example, most users do not need to see credit card numbers; therefore, the numbers are masked or hidden except for the last few digits. Least privilege refers to the minimum level of access needed, such as read-only versus edit.

Option Analysis

- **A - Incorrect:** Least privilege refers to the level of access
- **B - Correct:** Need to know limits access to needed information
- **C - Incorrect:** Availability is about access when needed
- **D - Incorrect:** Nonrepudiation is about proving origin

Q83: Integrity - Protection Against Modification

Question

Integrity refers to protection against:

A. Unauthorized disclosure
B. Improper modification, exclusion, or destruction of information
C. Unavailability of data when needed
D. Denial of an action

Q83: Explanation

Correct Answer: B

Integrity refers to protection against improper modification, exclusion, or destruction of information and applies to actions taken by both authorized and unauthorized users as well as processes or activities operating on the system. Whenever data is changed in a manner other than that intended by the data owner, integrity is compromised.

Option Analysis

- **A - Incorrect:** Unauthorized disclosure is a confidentiality breach
- **B - Correct:** Improper modification is an integrity breach
- **C - Incorrect:** Unavailability is an availability breach
- **D - Incorrect:** Denial is a nonrepudiation issue

Q84: Availability - 100% Uptime

Question

Why is an initial answer from process owners that systems require 100% availability often inaccurate?

A. Because process owners always exaggerate

B. Because the financial costs associated with guaranteeing true 100% uptime are rapidly apparent

C. Because availability is never important

D. Because systems are always available

Q84: Explanation

Correct Answer: B

Risk practitioners should anticipate an initial answer from process owners that systems and data are essential and require 100% availability. In most cases, this is not accurate, as rapidly becomes clear when the financial costs associated with guaranteeing true 100% uptime are presented. From there, the risk practitioner should work with the business to determine specific requirements and align these with what the organization is willing to pay.

Option Analysis

- **A - Incorrect:** Process owners are not exaggerating intentionally
- **B - Correct:** Cost of 100% uptime becomes apparent
- **C - Incorrect:** Availability is important
- **D - Incorrect:** Systems are not always available

Q85: Nonrepudiation Controls

Question

Which controls provide nonrepudiation?

A. Shared or generic logon credentials
B. Digital signatures and certificate-based authentication in a PKI
C. Simple usernames and passwords
D. Antivirus software

Q85: Explanation

Correct Answer: B

Digital signatures and certificate-based authentication in a public key infrastructure (PKI) are examples of controls whose proper implementation and use can provide nonrepudiation. Shared or generic logon credentials provide no assurance. Individual usernames and passwords provide relatively weak assurance because these can be shared or guessed.

Option Analysis

- **A** - **Incorrect:** Shared credentials provide no nonrepudiation
- **B** - **Correct:** Digital signatures and PKI provide nonrepudiation
- **C** - **Incorrect:** Usernames/passwords provide weak assurance
- **D** - **Incorrect:** Antivirus does not provide nonrepudiation

Q86: System Authorization Purpose

Question

What is the purpose of the system authorization process (also called security assessment and authorization)?

A. To install new software

B. To explicitly authorize a system to operate based on a thorough review of its security

C. To eliminate all risk from a system

D. To replace the need for testing

Q86: Explanation

Correct Answer: B

The system authorization process serves the purpose of explicitly authorizing a system to operate prior to it being allowed to do so. During assessment, an information system is thoroughly reviewed to determine the security of its design, development, testing, deployment, and operations. The culmination is a report to a suitably empowered senior manager recommending whether to authorize operation of the system.

Option Analysis

- **A - Incorrect:** Authorization is not about installing software
- **B - Correct:** Explicit authorization based on security review
- **C - Incorrect:** Risk cannot be eliminated entirely
- **D - Incorrect:** Testing is part of the assessment

Q87: Authorizing Official Responsibility

Question

Who is responsible for the formal decision to accept the risk and authorize a system for operational use?

A. The security evaluator
B. The authorizing official (AO)
C. The system administrator
D. The end users

Q87: Explanation

Correct Answer: B

Authorization is the official decision by a senior manager—sometimes called an authorizing official (AO)—to approve an information system for operational use. This decision is the explicit acceptance of the risk documented in the evaluator's report. The decision to accept risk is ultimately their responsibility as a senior manager accountable for business matters, not the evaluator who performed the assessment.

Option Analysis

- **A - Incorrect:** The evaluator assesses, not authorizes
- **B - Correct:** The AO accepts risk and authorizes
- **C - Incorrect:** Administrators operate systems
- **D - Incorrect:** End users use the system

Q88: Separation of Duties

Question

What is the purpose of separation of duties (SoD)?

- A To improve system performance
- B To prevent or detect errors and irregularities by assigning responsibility for initiating and recording transactions and custody of assets to separate individuals
- C To increase the number of administrators
- D To reduce IT costs

Q88: Explanation

Correct Answer: B

SoD is a basic internal control that prevents or detects errors and irregularities by assigning responsibility for initiating and recording transactions and the custody of assets to separate individuals. Most often, this takes the form of requiring one person to review and approve the work of another person.

Option Analysis

- **A - Incorrect:** SoD does not improve performance
- **B - Correct:** SoD prevents and detects errors
- **C - Incorrect:** SoD is not about increasing headcount
- **D - Incorrect:** SoD does not reduce costs

Q89: SoD and Collusion

Question

Why does separation of duties not guarantee security?

- A Because it is too expensive
- B Because it can be circumvented when all participants in the process agree to work together to bypass the intended effect (collusion)
- C Because it always fails
- D Because it is not a real control

Q89: Explanation

Correct Answer: B

SoD does not guarantee security because it can be circumvented when all participants in the process agree to work together to bypass the intended effect of the control (collusion). However, because it is difficult to establish collusion and especially challenging to maintain it over time, effective SoD increases the odds that an incorrect or fraudulent transaction will be detected and addressed.

Option Analysis

- **A** - **Incorrect:** Cost is not the reason
- **B** - **Correct:** Collusion can circumvent SoD
- **C** - **Incorrect:** SoD is effective when implemented well
- **D** - **Incorrect:** SoD is a real and important control

Q90: Job Rotation as Security Control

Question

Why is job rotation an effective security mechanism?

A. It improves productivity

B. It changes who is involved in which roles at which times, reducing the potential for collusion and increasing the odds that prior collusion can be detected

C. It reduces training costs

D. It eliminates all fraud

Q90: Explanation

Correct Answer: B

Job rotation is typically associated with business continuity and enterprise resiliency, but it is also an effective security mechanism because it changes who is involved in which roles at which times, reducing the potential for collusion and increasing the odds that prior collusion can be detected by someone who is not part of the scheme. In environments where there is substantial concern regarding collusion, job rotation may take the form of mandatory vacations.

Option Analysis

- **A - Incorrect:** Rotation can decrease efficiency during transitions
- **B - Correct:** Rotation reduces collusion potential
- **C - Incorrect:** Rotation increases training costs
- **D - Incorrect:** Rotation does not eliminate all fraud

Q91: Identification Purpose

Question

What is the purpose of identification in the access control process?

- A To prove the user's identity
- B To assign a unique identifier to every individual, device, or process that has access to a system, enabling per-user tracking and logging
- C To determine what resources a user can access
- D To record user actions for auditing

Q91: Explanation

Correct Answer: B

With a unique identifier assigned to every individual, device, or process that has access to a system, it is possible to track and log activity on a per-user basis, creating the possibility of a targeted investigation were a problem to arise. Identification is often provided through a user ID, customer account number, employee identification number, or other unique element.

Option Analysis

- **A - Incorrect:** Authentication proves identity
- **B - Correct:** Identification enables per-user tracking
- **C - Incorrect:** Authorization determines access
- **D - Incorrect:** Accountability records actions

Q92: Authentication Factors

Question

Which of the following correctly lists the three factors of authentication?

A. Something you know, something you have, something you are
B. Something you want, something you need, something you see
C. Identification, authorization, accountability
D. Password, username, token

Q92: Explanation

Correct Answer: A

Authentication is done using one or more of three factors: something you know (e.g., user ID, password), something you have (e.g., token, authenticator), and something you are (e.g., fingerprint, iris scan). Multifactor authentication (MFA) combines more than one factor during the login process to establish strong authentication.

Option Analysis

- **A - Correct:** Know, have, are
- **B - Incorrect:** Not valid authentication factors
- **C - Incorrect:** These are IAAA components
- **D - Incorrect:** Password and username are knowledge factors; token is possession

Q93: Password Authentication Weakness

Question

Why is authentication by knowledge (e.g., passwords) considered weak over time?

A. Because passwords are never used

B. Because time is the enemy of knowledge authentication—any knowledge question can eventually be figured out, allowing one person to log in as another

C. Because passwords are always too complex

D. Because passwords cannot be changed

Q93: Explanation

Correct Answer: B

Time is the enemy of knowledge authentication, because any knowledge question can eventually be figured out, allowing one person to log in as another. Therefore, changing passwords on a regular basis is recommended even in high-complexity environments. Knowledge is often subject to replay attacks, even when what is asked is complex.

Option Analysis

- **A - Incorrect:** Passwords are widely used
- **B - Correct:** Knowledge can eventually be compromised
- **C - Incorrect:** Complex passwords are used for extended periods
- **D - Incorrect:** Passwords can and should be changed

Q94: Possession Authentication Downside

Question

What is a key downside of possession-based authentication (e.g., tokens, smart cards)?

A. It is too secure

B. If the means of authentication is lost, stolen, or damaged, the legitimate user may be denied access without easy recourse

C. It is too cheap

D. It cannot be used with mobile phones

Q94: Explanation

Correct Answer: B

A downside of possession-based authentication is that should the means of authentication be lost, stolen, or damaged, the legitimate user may be denied access without easy recourse. Where availability is a primary concern, the risk practitioner should take care to examine what workarounds may be in place, keeping in mind that any workaround also represents a potential area of vulnerability.

Option Analysis

- **A - Incorrect:** No authentication is too secure
- **B - Correct:** Loss of token denies legitimate access
- **C - Incorrect:** Possession authentication can be expensive
- **D - Incorrect:** Mobile phones enable possession authentication

Q95: Biometric Authentication Concern

Question

What is a significant concern with biometric authentication?

- A. It is always inaccurate
- B. Biometric data may be subject to laws and regulations governing privacy, with potentially severe penalties should the data be compromised
- C. It cannot be used for access control
- D. It is too easy to fake

Q95: Explanation

Correct Answer: B

Biometric data may be subject to laws and regulations governing privacy, with potentially severe penalties in some jurisdictions should the data be compromised. Also, while it is generally assumed that a person would not lose characteristics in ways that might deny access, this assumption does not hold under all conditions—soldiers or workers in industrial environments might experience physical injuries that affect their eyes or limbs.

Option Analysis

- **A - Incorrect:** Biometrics are generally accurate
- **B - Correct:** Privacy regulations create legal risk
- **C - Incorrect:** Biometrics are used for access control
- **D - Incorrect:** Biometrics are difficult to fake

Q96: Multifactor Authentication Dependency

Question

What risk do many MFA implementations introduce by relying on personal smartphones?

A. They are too secure

B. Authentication becomes reliant on access to devices outside organizational control, which may be lost, damaged, or stolen

C. They eliminate all fraud

D. They do not require passwords

Q96: Explanation

Correct Answer: B

Many MFA implementations combine traditional passwords with codes sent to or generated by applications on personal smartphones. These arrangements, while convenient, make authentication reliant on access to devices outside organizational control. Should a mobile device required for MFA be unavailable, the result is likely to be a temporary inability of a valid user to authenticate.

Option Analysis

- **A - Incorrect:** No MFA is too secure
- **B - Correct:** Dependency on personal devices
- **C - Incorrect:** MFA does not eliminate fraud
- **D - Incorrect:** MFA often still requires passwords

Q97: Authorization - Least Privilege

Question

What does proper employment of least privilege ensure in authorization?

A. That all users have full control over data

B. That employees only have the level of access they require to perform their job functions

C. That access is never restricted

D. That all users have administrative access

Q97: Explanation

Correct Answer: B

Authorization refers to the privileges or permissions the person will have. Proper employment of least privilege is important to ensure that employees only have the level of access they require to perform their job functions. Permissions may be applied on a per-file or per-folder basis.

Option Analysis

- **A - Incorrect:** Full control violates least privilege
- **B - Correct:** Least privilege limits access to what is needed
- **C - Incorrect:** Access must be controlled
- **D - Incorrect:** Not all users need administrative access

Q98: Authorization Isolation

Question

How does authorization isolation based on time or location improve security?

A. It allows access from anywhere at any time

B. It prevents a user from using account privileges at times or locations when they should not be required, reducing the potential scope of monitoring

C. It eliminates the need for authentication

D. It gives users more privileges

Q98: Explanation

Correct Answer: B

Authorization is typically granted only for a limited period. This isolation on a time- or location-delineated basis prevents a user from using account privileges at times when they should not be required and allows an organization to maximize the effectiveness of its controls by reducing the potential scope of monitoring. For example, access might only be allowed during normal working hours.

Option Analysis

- **A - Incorrect:** Isolation restricts access
- **B - Correct:** Time/location isolation reduces misuse potential
- **C - Incorrect:** Authentication is still required
- **D - Incorrect:** Isolation restricts, not expands, privileges

Q99: Accountability - Log Protection

Question

Why should audit logs not be changeable by operations staff, even administrators?

A. To save storage space

B. To prevent a user from disabling the logging function or altering log data that implicates their own account in suspicious or malicious activity

C. To improve system performance

D. Because logs contain no useful information

Q99: Explanation

Correct Answer: B

To prevent a user from disabling the logging function or altering log data that implicates their own account in suspicious or malicious activity, audit logs should not be changeable by operations staff—even administrators. Logs also may contain sensitive data, so even view access to log content should be strictly controlled based on clear business need.

Option Analysis

- **A - Incorrect:** Storage is not the primary concern
- **B - Correct:** Prevents tampering with evidence
- **C - Incorrect:** Performance is not the reason
- **D - Incorrect:** Logs contain valuable evidence

Q100: Symmetric Key Distribution

Question

What is the primary challenge with symmetric key cryptography?

- A It is too slow for bulk data
- B The need for one party to deliver keys to another with whom it would like to exchange data, which is difficult in environments like e-commerce with unknown parties
- C It uses too much processing power
- D It cannot encrypt large messages

Q100: Explanation

Correct Answer: B

Symmetric key cryptography has two major disadvantages. One is the need for one party to deliver keys to another with whom it would like to exchange data. Where communications are established between trusted parties, this may be workable through physical methods. However, in environments such as e-commerce, customers are unknown and not trusted entities, making brokering a connection more difficult.

Option Analysis

- **A - Incorrect:** Symmetric is fast for bulk data
- **B - Correct:** Key distribution is the main challenge
- **C - Incorrect:** Symmetric uses less processing power than asymmetric
- **D - Incorrect:** Symmetric encrypts large messages efficiently

Q101: Asymmetric Key Relationship

Question

In asymmetric encryption, what is the relationship between the public and private keys?

A. They are identical

B. They are mathematically related, but it is computationally infeasible to determine one from the other

C. They have no relationship

D. The public key can decrypt what the private key encrypts, but not vice versa

Q101: Explanation

Correct Answer: B

In a Diffie-Hellman setup, two mathematically related keys are created: a private key and a public key. It is computationally infeasible to determine the value of one key from the other, but the manner of their generation means that each has the effect, when used in an appropriate asymmetric algorithm, of creating ciphertext that only the other has the ability to return to plaintext.

Option Analysis

- **A - Incorrect:** Keys are different
- **B - Correct:** Mathematically related but infeasible to derive
- **C - Incorrect:** They are mathematically related
- **D - Incorrect:** Each can decrypt what the other encrypts

Q102: Asymmetric Algorithm Usage

Question

Why are asymmetric algorithms typically used only to encrypt short messages?

A. They are less secure than symmetric algorithms

B. They are computationally intensive and slow relative to symmetric algorithms

C. They cannot encrypt any data

D. They require no keys

Q102: Explanation

Correct Answer: B

Asymmetric algorithms are computationally intensive and slow relative to symmetric algorithms. For that reason, asymmetric cryptography is typically used only to encrypt short messages. The most common use of asymmetric algorithms is to distribute symmetric keys that can then be used by the participants for fast, secure communication.

Option Analysis

- **A - Incorrect:** Asymmetric is not less secure
- **B - Correct:** Asymmetric is slow and intensive
- **C - Incorrect:** Asymmetric can encrypt data
- **D - Incorrect:** Asymmetric requires key pairs

Q103: Hashing Purpose

Question

What is the original purpose of hashing algorithms?

A. To encrypt messages for confidentiality
B. To detect accidental errors caused by interference or network problems
C. To provide nonrepudiation
D. To replace digital signatures

Q103: Explanation

Correct Answer: B

Hashing by itself provides effective protection against accidental changes in a message, such as those caused by interference, and this was its original purpose. When a sender wants to ensure a message is not affected by noise or network problems, he or she can hash the message and send the digest along with the message. The receiver can then hash the received message and verify that the resulting digest matches.

Option Analysis

- **A - Incorrect:** Hashing does not provide confidentiality
- **B - Correct:** Hashing detects accidental errors
- **C - Incorrect:** Hashing alone does not provide nonrepudiation
- **D - Incorrect:** Digital signatures use hashing, not replace it

Q104: Hashing Limitation

Question

Why is hashing alone insufficient to protect against intentional changes to a message?

A. Because hashes are too long

B. Because a malicious user who intercepts a transmission can create a new digest after altering the message

C. Because hashes cannot be calculated

D. Because hashes are always wrong

Q104: Explanation

Correct Answer: B

A malicious user who intercepts a transmission that includes a hash will not be deterred by hashing, because they can create a new digest after altering the message. To guarantee integrity against intentional and accidental changes, cryptologists extended the basic idea of hashing to include features of public key encryption, resulting in digital signatures.

Option Analysis

- **A - Incorrect:** Hash length is not the issue
- **B - Correct:** Attacker can recompute the hash
- **C - Incorrect:** Hashes are easily calculated
- **D - Incorrect:** Hashes are reliable when computed correctly

Q105: Digital Signature Nonrepudiation

Question

Why does a digital signature provide nonrepudiation?

- (A) Because anyone can create the signature
- (B) Because only the sender's private key could have encrypted the digest, so the sender cannot plausibly deny sending it
- (C) Because the signature is symmetric
- (D) Because the signature is public

Q105: Explanation

Correct Answer: B

A digital signature combines a hash function with the ability of public key encryption to prove the author's identity. The recipient's ability to decrypt the digital signature with the sender's public key means that it must have been encrypted with the sender's private key and is, therefore, the genuine digest for the message. Moreover, the sender cannot plausibly deny it, because only the sender's private key could have encrypted it.

Option Analysis

- **A - Incorrect:** Only the private key holder can sign
- **B - Correct:** Private key encryption proves origin
- **C - Incorrect:** Digital signatures use asymmetric encryption
- **D - Incorrect:** The signature is not simply public

Security Concepts Key Takeaways

Essential Concepts

- CIA triad involves trade-offs; you can't maximize all three
- Need-to-know limits access to needed information; least privilege limits access level
- Nonrepudiation requires digital signatures or PKI certificates
- SoD prevents errors but can be circumvented by collusion
- Job rotation reduces collusion potential
- Authentication factors: know, have, are
- Knowledge authentication weakens over time; possession has availability downsides
- Biometrics carry privacy regulation risk
- Symmetric key distribution is the main challenge; asymmetric is slow
- Hashing protects integrity but cannot prove origin; digital signatures provide nonrepudiation

Final Advice

Exam Preparation

Remember:

- Understand the *why* behind each technology risk concept
- Know the difference between similar terms
- Understand how emerging technologies introduce new risk
- Practice scenario-based questions
- Use the ISACA mindset

Good Luck on Your CRISC Exam!